

Introduction to Web & Infrastructure Security

Lesson 1 · Core concepts, threats, principles and how this course works

Today's agenda



01 Why security matters

Real costs and real numbers



02 Core concepts

CIA triad, AAA, threat · vulnerability · risk



03 Attackers and attack surface

Who attacks, and where a web system is exposed



04 Security principles

Defense in depth, least privilege, and more



05 OWASP Top 10 and CVE/CVSS

How vulnerabilities are classified and scored



06 Ethics and course rules

What is allowed, labs, grading, homework

Why security matters

$4.88M

average cost of a data breach

IBM Cost of a Data Breach, 2024

68%

of breaches involve a human element

Verizon DBIR, 2024

40,000+

new CVEs published in one year

NVD, 2024

Every web app is exposed. Automated bots scan the whole internet continuously. A new server with SSH open usually gets its first login attempts within minutes, not days.

PART 02 OF 06

02

Core concepts

The vocabulary we will use in every lab



The CIA triad



Confidentiality

Only authorized people can read the data.

- Attack: stolen database, sniffed password
- Defense: encryption (TLS), access control



Integrity

Data is not changed without authorization.

- Attack: modified price in a request, defaced site
- Defense: validation, hashes, signatures



Availability

The system works when users need it.

- Attack: DoS/DDoS, ransomware
- Defense: rate limiting, backups, redundancy

Beyond CIA: who are you, and what may you do?



Authentication

Proving who you are

Passwords, keys, MFA, certificates



Authorization

Deciding what you are allowed to do

Roles, permissions, ownership checks



Accounting / Auditing

Recording who did what, and when

Logs, audit trails, monitoring

Common mistake: checking that a user is logged in (authentication) but not that the record belongs to them (authorization).

Threat, vulnerability, risk

Asset	Vulnerability	Threat	Risk
What we protect	**A weakness**	**Who or what can exploit it**	**Chance × damage**
e.g. User database, server, reputation	*e.g. SSH open with password login allowed*	*e.g. Bots trying common passwords*	*e.g. Server takeover, data leak*

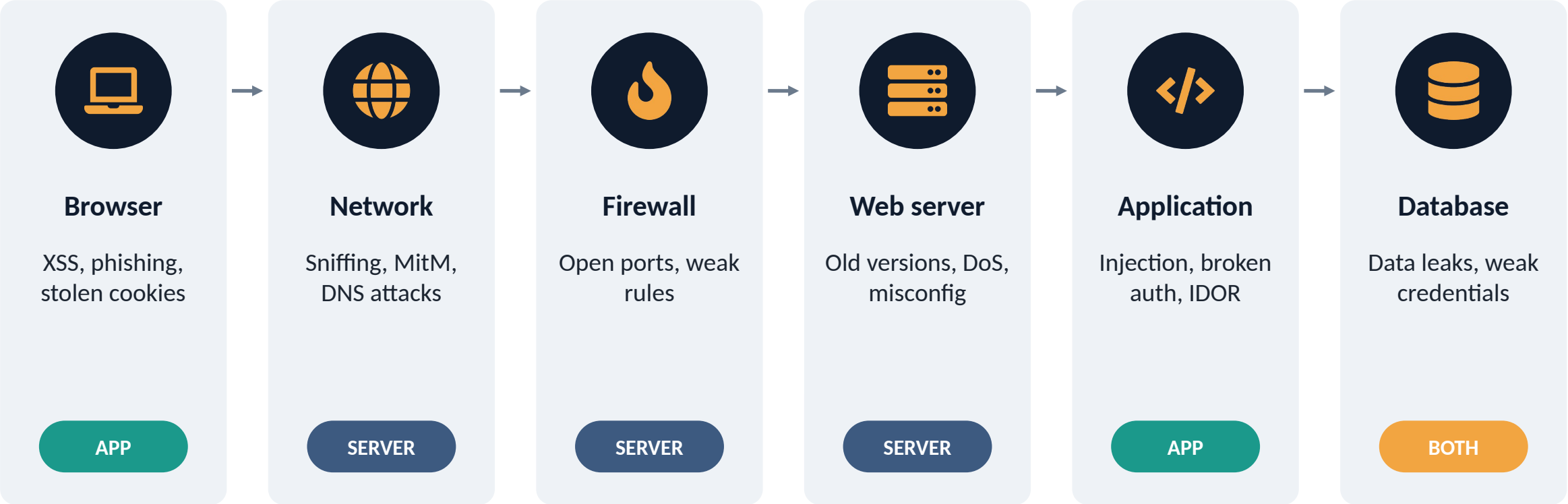
Risk = Likelihood × Impact

Control (fix): SSH keys only, Fail2ban, firewall.
We rarely remove a threat. We reduce the vulnerability or the impact, and that lowers the risk.

Who attacks, and why

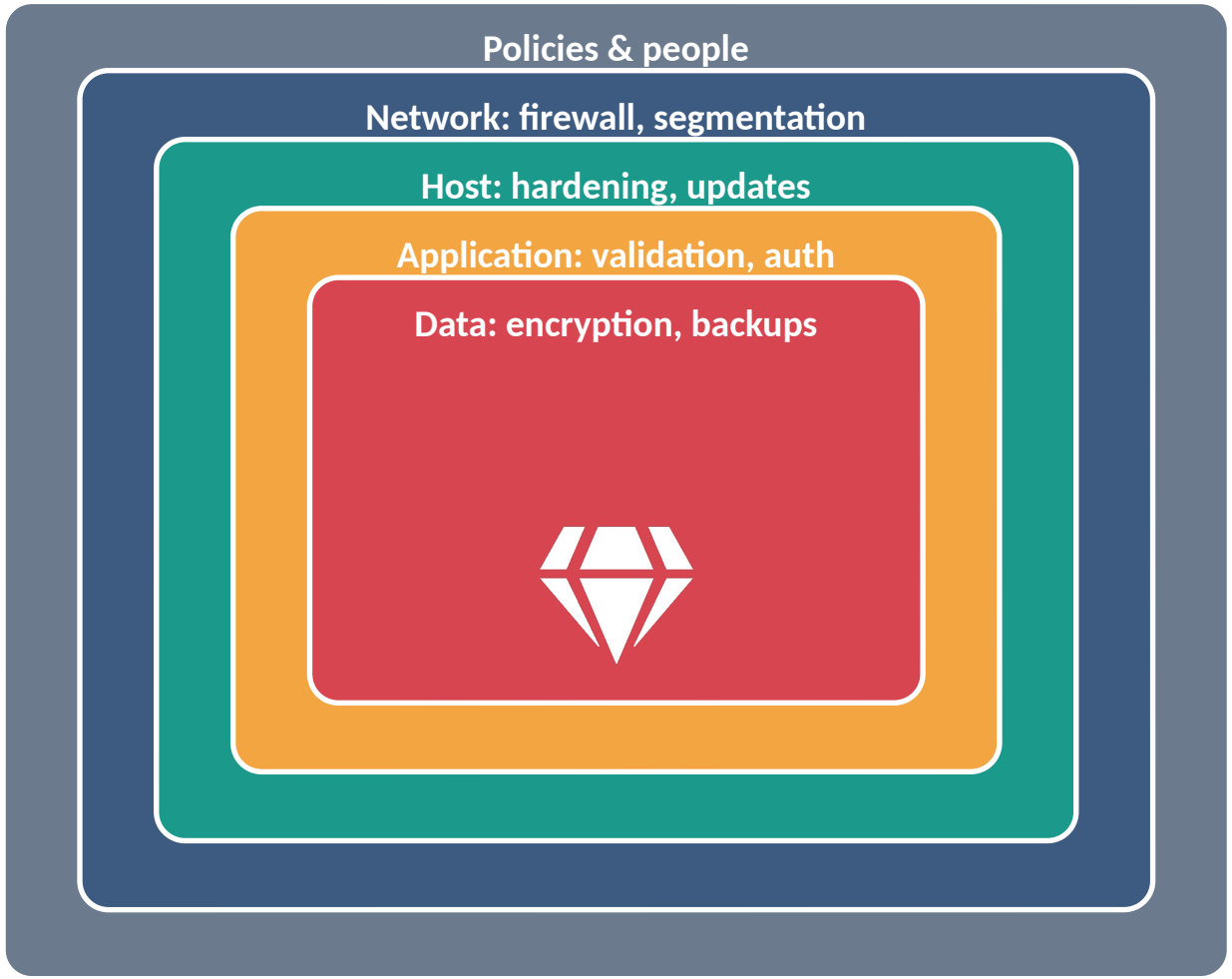
Attacker	Motivation and methods	How often you meet them
Automated bots	Scan everything, try default passwords and known CVEs	Very high
Cybercriminals	Money: ransomware, stolen data, fraud	High
Insiders	Employees or ex-employees, by mistake or on purpose	Medium
Hacktivists	Political or social message, defacement, DDoS	Medium
State-sponsored groups	Espionage, sabotage, long-term access	Low, high impact

Attack surface of a web system



Attack surface = every point where an attacker can send input or reach the system. Our job: make it **smaller** and defend each point.
APP = Part 1 (Labs 1–3), SERVER = Part 2 (Labs 4–5).

Defense in depth



No single control is perfect.

Stack several independent layers, so an attacker who gets through one still meets the next.

Example: SQL injection

- Input validation rejects bad data (Lab 2)
- Parameterized queries fix the code (Lab 2)
- DB user has minimal rights (least privilege)
- Logs show the attempts (Lab 4)

Six principles to remember

Least privilege

Give each user and process only the rights it needs, nothing more.

Minimize attack surface

Close unused ports, remove unused services, packages and features.

Secure by default

Default config must be safe: no default passwords, debug mode off.

Never trust input

Validate everything from users, headers, files and other services.

Fail securely

On error, deny access and show no stack traces or internals.

Keep it updated

Patch OS, libraries and containers. Old software = known CVEs.

OWASP Top 10:2025 – the most critical web risks

A01	Broken Access Control	Lab 3
A02	Security Misconfiguration	Labs 4, 5
A03	Software Supply Chain Failures	Lab 5
A04	Cryptographic Failures	Labs 3, 5
A05	Injection	Lab 2
A06	Insecure Design	Lab 1
A07	Authentication Failures	Lab 3
A08	Software or Data Integrity Failures	Lab 5
A09	Security Logging & Alerting Failures	Lab 4
A10	Mishandling of Exceptional Conditions	Lab 2

owasp.org/Top10 · right column: the lab where we practice it

CVE and CVSS: naming and scoring vulnerabilities

CVE = a unique ID

CVE-2021-44228

year + number · this one is Log4Shell (Apache Log4j)

CVSS = severity score 0–10

Based on: how it is reached (network or local), how hard it is, privileges needed, user interaction, and the impact on C, I and A.

None	Low	Medium	High	Critical
0.0	0.1–3.9	4.0–6.9	7.0–8.9	9.0–10

In Lab 5 npm audit runs in your GitHub Actions pipeline and lists known CVEs in the app's dependencies. You decide what to fix first: start with Critical and High.

PART 06 OF 06

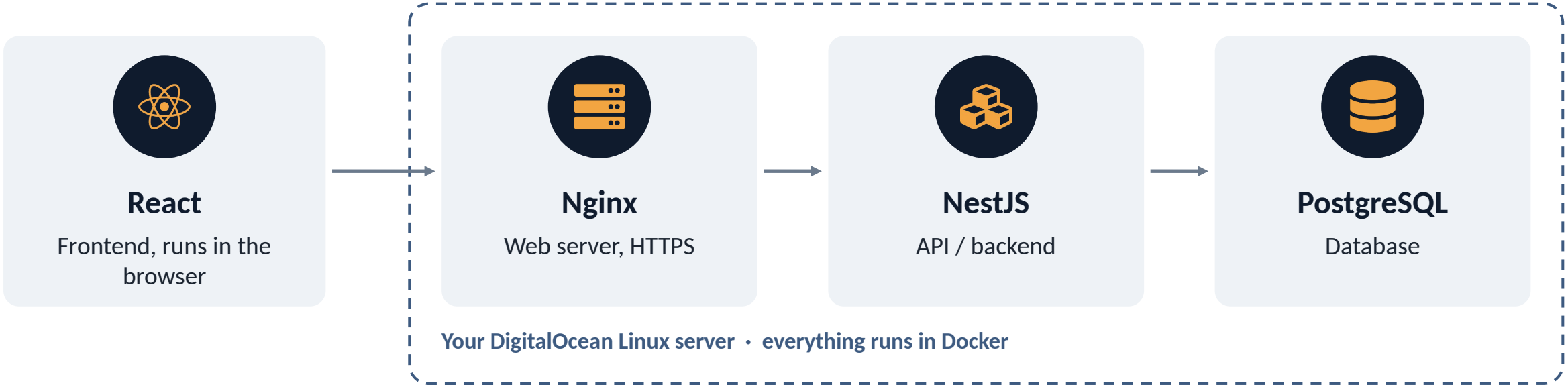
06

How this course works

5 labs · 1 project · 1 rule: only attack what you own



One app, all semester: secure the Notes app



What you will secure:

- Database queries
- Login & passwords
- Access to notes
- Linux server
- Nginx & HTTPS

You get a working app with hidden vulnerabilities. You find them, fix them, then deploy the app securely with GitHub Actions.

5 labs, one project

Lab 1 — **Run the app & find the risks** — APP

Notes app (NestJS + React + PostgreSQL) in Docker · threat model · secrets in .env · database not exposed

Lab 2 — **Fix injection: SQL injection & XSS** — APP

Find both in the code · parameterized queries · input validation · safe rendering in React

Lab 3 — **Secure login & access** — APP

Password hashing (bcrypt) · JWT · only your own notes (IDOR) · login rate limiting

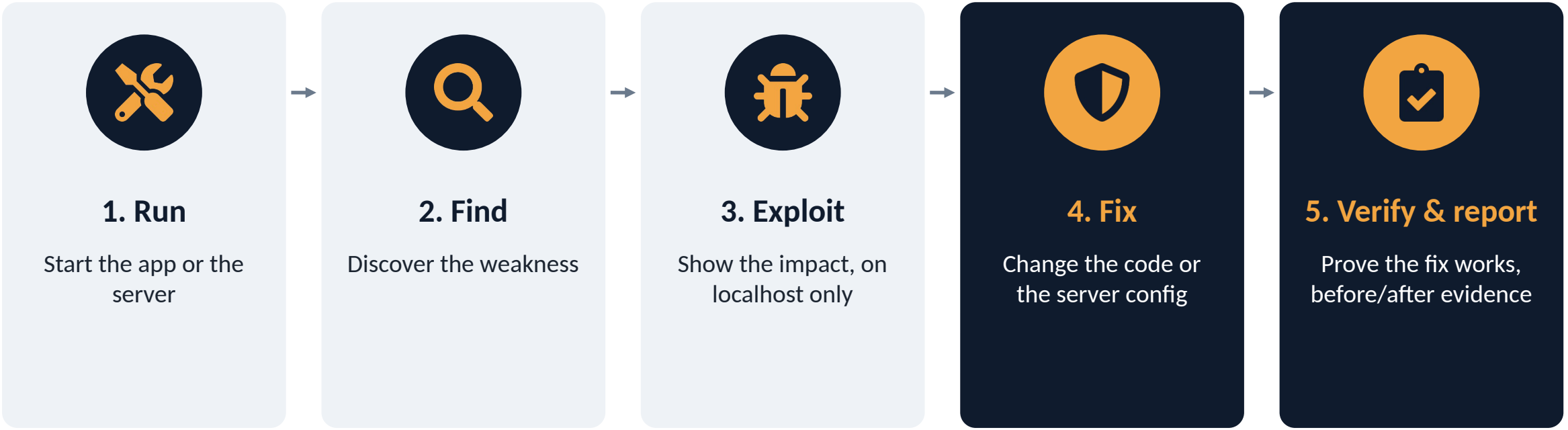
Lab 4 — **Secure the Linux server** — SERVER

DigitalOcean server · SSH keys only · ufw firewall · Fail2ban · automatic updates

Lab 5 — **Secure the web server & deploy** — SERVER

Nginx · HTTPS (Let's Encrypt) · security headers · rate limiting · GitHub Actions + npm audit

Every lab follows the same cycle



Most of your grade comes from steps 4 and 5. Breaking something is easy. Explaining why it broke and fixing it properly is the real skill, and it is what employers pay for.

Ethics and law: the most important slide



Allowed

- Your own laptop and DigitalOcean server
- Intentionally vulnerable practice apps
- Systems where you have written permission
- CTF platforms, within their rules
- Reporting bugs through responsible disclosure



Not allowed

- Scanning the university or any public network
- Testing a real website "just to see"
- Keeping or sharing captured passwords or data
- Using lab techniques outside the lab
- Running tools you do not understand

Unauthorized access to computer systems is a criminal offense in Moldova, in the EU (Directive 2013/40/EU) and almost everywhere else. Good intentions are not a defense.

Grading

60%

Lab reports

Findings, impact, fix, before/after evidence

20%

Final assessment

Present your secured app, live on your own server

20%

Quiz / oral defense

Explain the concepts behind one of your labs

Report deadline: before the next lab. Late reports and copied reports are penalized. Use the report template on the course page.

Before Lab 1

1



Prepare your machine

Linux laptop or VM with Docker, Node.js 22, Git and VS Code. Create GitHub and DigitalOcean accounts.

2



Read

OWASP Top 10 overview (owasp.org/Top10). Pick one item and be ready to explain it in 2 minutes.

3



Think

For a notes app with login and a database: list 5 assets, 3 threats and 1 thing to protect first.



“Security is a process, not a product.”

Bruce Schneier · Questions?